



File No.: EXP202313747

RESOLUTION FOR TERMINATION OF THE PROCEDURE BY RECOGNITION OF RESPONSIBILITY AND VOLUNTARY PAYMENT

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On March 27, 2025, the Presidency of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against A.A.A. (hereinafter, A.A.A.), through the agreement that is transcribed:

<<

File No.: EXP202313747

AGREEMENT TO INITIATE SANCTIONING PROCEEDINGS

From the actions taken by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: The Spanish Agency for Data Protection has become aware of certain facts that could constitute a possible infringement attributable to A.A.A., with NIF ***NIF.1 (hereinafter, the reported party or A.A.A.).

The facts brought to the attention of this authority:

The reported party is the owner of a pharmacy located in ***LOCALIDAD.1, where a collection of personal data, including health-related data, of many patients who visit it is being carried out, conducted when the patient wishes to renew the medication recorded on the health card of the Health System of the Community of Castilla y León (Sacyl).

To do this, according to the reporting person, the card is passed through the reader while an "Excel" file is open, (...), noting and storing in that file the medication that the patient wishes to renew along with their personal data, "without guarantees of protection or informed consent."

It is indicated that the pharmacy has several computers located at two counters in the establishment, at which these "Excel" files with the names "(...)" can be found.

It is added that "Medication is also being dispensed without the physical card from the health system of Castilla y León (Sacyl) and without the patient being physically present in the pharmacy. (...) where information extracted from the magnetic strip of the health card is cut without informed consent to access the medication and health data of the patient in question."

The files mentioned in the complaint are provided, (...).

From the examination of these documents, the following results:

- The first of the files includes three sheets:
 - Sheet 1: with annotations of dates between 01/18/2018 and 03/22/2023 and 1,746 groups with personal data related to the Autonomous Community Personal Identification Code (CIPA), Patient Identification Code in the National Health System (CIP), name and surname of the patient, name of the health center, name and surname of the doctor, and indications for the doctor (includes the word "medication," or names of medications, preceded by the indication "renew" in 1,444 of the cases).
 - Sheet 2: with annotations of dates between 01/18/2020 and 12/31/2021 and 13,050 groups with personal data related to CIPA, CIP, and name and surname of the patient.
 - Sheet 4: 5 groups with data similar to those collected in Sheet 2.
 - The first of the files includes three sheets:
 - Sheet 1: annotations of dates between 10/05/2018 and 03/08/2023 and 1,179 groups with data similar to those collected in Sheet 1 of the previous file (with the indication "renew" in 912 of the cases).
 - Sheet 2: with annotations of dates between 01/25/2020 and 02/03/2023 and 10,038 groups with personal data related to CIPA, CIP, and name and surname of the patient.
 - "antigen test": 7 groups with data related to name or name and surname and mobile phone number.
- SECOND: As a consequence of the known facts and their relevance, on 10/06/2023, the Director of the Spanish Agency for Data Protection urged the General Subdirectorate of Data Inspection (SGID) to

initiate the preliminary investigation actions referred to in Article 67 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD). THIRD: The General Subdirector of Data Inspection proceeded to carry out preliminary investigation actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VIII of the LOPDGDD.

1. A request for information was sent to the reporting person to provide photographs showing the situation of the computers, photographs or copies of the desks of the computers where the icons of the mentioned files appear.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sede.aepd.gob.es
3/32

files, or the path to the directory in which they are located, and photographs or a sequence of the process of copying the data to the spreadsheets.

A response was received, dated 09/12/2023, providing images showing the location of the computers on the public sales counters, and images of one of the "Excel" sheets referred to in the complaint. In this response, it is stated that when "the card is swiped with the Excel program open, the information is saved in a cell of the program and immediately cut and pasted (...). With this information, medication is dispensed without the cardholder being present."

2. On 19/02/2024, an on-site inspection was conducted at the pharmacy office that was reported. In this act, as recorded in the inspection report, the Inspection Services of the AEPD accessed the computers of the pharmacy office, finding the following files, of which the reported party provided copies:

. (...).
. (...).
. (...).

The inspection report states that these files contain data from 04/10/2023 to 05/02/2024.

Furthermore, according to the report of actions prepared by those Services, the types of data found in these files match those found in the documents provided with the complaint:

- Date
- Autonomous Community Personal Identification Code of the patient (CIPA).
- Patient identification code in the National Health System (CIP).
- Name and surname of the patient.
- Name of the health center.
- Name and surname of the doctor.
- Instructions for the doctor (in most cases: "renew," followed by "medication" or names of medications or health products).
- In the documents provided with the complaint, phone numbers appear.
- Notation of having been sent

Upon examining the documents, it is confirmed that they include the following information:

. (...). Contains 3 groups with data related to CIPA, CIP, name and surname of the patient, health center, name and surname of the doctor (in 1 group) and instructions for the doctor (in 1 case it indicates "renew iron").

. (...). Contains two "Excel" sheets: the first one with 50 groups of data with annotations dated between 04/10/2023 and 05/02/2024 and the same data as the previous file; the second contains 819 groups of data with annotations dated between 28/11/2023 and 27/12/2023 and the data related to CIPA, CIP, and name and surname of the patient.

. (...). Also with two "Excel" sheets: one of them with 11 groups of data with annotations dated between 26/10/2023 and 29/01/2024 and the same data collected in the first sheet of the previous files; the other contains 58 groups of data with annotations all dated 28/11/2023 and data related to

CIPA, CIP, and name and surname of the patient.

It is also recorded in the Inspection Report that, after being informed that the inspection visit is related to the storage on the computers of personal data of clients extracted from the system (...), the person in charge of the pharmacy office made the following statements:

“. Purpose: to facilitate the renewal of medication without the patient having to go to the health center. To do this, they send an email to the health center with the patient's data, the doctor who made the prescription, and the medication.

Additionally, the inspected party states that they use the registered data to access the electronic prescription module and register the sale in the electronic prescription system without the patient being present in the pharmacy, in case of communication error, time exceeded, computer error, etc.

. Information provided to clients about this treatment: no specific information is provided to clients about this treatment. However, the inspected party states that the client has visual access at all times to the computer screen to see what is being done.

. Personnel with access to the computers containing the files and whether these are password protected: the inspected party states that at the time of the inspection, in addition to himself, three employees in the pharmacy have permission to access. (...).

Information was requested from the inspected party regarding whether these files are stored elsewhere as a backup or for any other purpose and, in this case, the retention period of these files: the inspected party responds that these files are not copied or stored anywhere else.

. When asked what procedure is used to transfer the personal data of clients to the Excel files, he states that the data from the health card is automatically transferred to the Excel file when the card is swiped through the magnetic reader and the rest of the data is entered manually (the medication data is extracted (...) and the data of the doctor and health center from what is printed on the health card)."

3. In light of indications of irregular processing of personal data in health centers in Castilla y León, on 27/02/2024, a request for information was made to the Regional Health Management regarding the processing of personal data carried out for the renewal of prescriptions.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaeapd.gob.es

5/32

In response to this request, writings were received from the DPD of SACYL on April 1, April 15, April 19, and May 24, 2024.

A) The response of 01/04/2024 consisted of the submission, among others, of the following documents:

a) "Procedure for direct communication between pharmacies and doctors/nurses of health centers" (includes at the top the logos of "Sacyl" and "Primary Care Valladolid Oeste").

The document presents the need for pharmacies to collaborate in the detection of errors and to optimize the effectiveness of medication dispensations and the safety of patients. It then states:

"In 2016, a communication system was initiated between doctors and pharmacies in collaboration with the College of Pharmacists of Valladolid for the direct resolution of incidents in Electronic Prescription (RE) through the email sending of a template that has been extended to urban and semi-urban centers in the area."

The objective is for the incident to be resolved "without the patient having to attend a consultation, to avoid misunderstandings and unnecessary travel for the patient, reduce the time spent by the doctor on resolving this type of incident, and to promote the collaboration of community pharmacists in the detection of medication errors."

The incidents that can be resolved through this means are described:

- Closed dispensing window: valid for interrupted dispensing at the pharmacy when the patient does not collect the medication within the indicated periods. "Not valid for treatment renewals; the patient must attend a consultation."

- Error or doubts regarding posology.

- Active treatment that the patient does not use. Helps to detect treatments that the patient does not

need or duration errors.

- Others.

It is warned that "this procedure is not valid for renewals or for recovering closed treatments, as the patient must attend a consultation for individual assessment; therefore, in these cases, no action will be taken, and the pharmacy will refer the patient to the health center."

The procedure to be followed is then described:

"The pharmacist fills out the form 'Communication and incidents detected in pharmacies with electronic prescription' and sends it by email to the management mailbox of the health center corresponding to the patient..."

The person in charge of... each health center forwards the incident communication to the patient's doctor or nurse depending on the type of incident communicated...

The doctor or nurse assesses the incident and, if appropriate, resolves it...

Each health center will determine how to manage these incidents (creation of a non-presential consultation, resolution at the end of the consultation, etc.)."

When detailing the procedure, it is indicated to the healthcare professionals that "treatment renewals should not be made without seeing the patient nor should closed treatments be recovered."

b) Communication that the Official College of Pharmacists of Valladolid sent to its members regarding the direct communication procedure described in the previous subsection a) (with the file name "protocol incidents RE mail feb20 (1).pdf"):

"The information contained in this document is for the exclusive use of the members of the Official College of Pharmacists of Valladolid solely for the purpose of communicating incidents detected in pharmacies with electronic prescriptions.

We inform you that, in the following Basic Health Zones of the capital and province, a protocol for communicating electronic prescription incidents is operational, and although your Health Center is not yet included, you can report incidents corresponding to patients belonging to that Center.

It involves sending the completed template via email with the detected incident:

- Closed dispensing window
- Posology error
- Active treatment that the patient does not use
- Lack of signature
- Others

Within 48 hours, the doctor, if deemed appropriate, will resolve the incident without the need for the patient to return to consultation."

The emails to which the template must be sent are then indicated (20 addresses of health centers in the city of Valladolid and two from the province).

c) "Communication of incidents detected in pharmacies with electronic prescriptions" (with the file name "Template incidents electronic prescription mayo19 (5).docx"). It includes fields to record the following information:

- Pharmacy
- Health Center
- Prescribing doctor
- CIP/CIPA of the patient
- Detected incident (options can be marked: Closed dispensing window; Posology error; Active treatment that the patient does not use; Others)
- Affected medications

7/32

Contact details of the pharmacy (telephone and email address)

d) Various emails sent by the reported pharmacy office to different health centers are provided, attaching the previously completed form. In the "subject" of these emails, it is indicated "Renew electronic prescription," "Incident electronic prescription," or "Renew medication."

B) The response dated 15/04/2024 consisted of the following documents:

a) Report from Sacyl regarding the communication procedure referred to in section A) above (this document was resent with the response dated 25/05/2024).

This report refers to the implementation of the electronic prescription throughout the years 2015 and 2016 and to the specific difficulties detected in pharmacy offices, indicating that this led some areas of Sacyl, such as Valladolid Este and Valladolid Oeste, to establish an agile communication procedure between pharmacy offices and health centers, which has resolved incidents and received adequate acceptance from professionals and patients.

It adds that, following the request from the AEPD, aspects have been identified that "are not in accordance with the LOPDGDD," so it has been assessed with the two Primary Care Managements to review the communication circuit, in order to respond to the needs and respect the processing of personal data of users, and also to review "the motivation for the communications made through this circuit to limit its use to the causes and reasons initially defined in the procedure."

b) Response from the Primary Care Management of Valladolid Este, dated 11/04/2024:

Emails are sent to the address "(...)@...", created in each health center for communication, instructions, messages, and exchange of documentation.

It reiterates the reasons that led to designing, together with the Official College of Pharmacists of Valladolid, the indicated communication procedure between pharmacists and family doctors, with the purpose of resolving incidents that did not allow dispensing but also did not require a face-to-face consultation with the physician.

C) The response dated 19/04/2024 includes a report from the Primary Care Management of Valladolid Oeste.

This document again explains the reasons and purpose that led to establishing that procedure in 2017, agreed upon by the Primary Care Managements of Valladolid (Este and Oeste) and the Official College of Pharmacists of the province, highlighting that it was very effective for managing some incidents such as interrupted dispensing, but was not valid for requesting renewal of treatments. It refers to the form used to communicate incidents, already detailed, and to the individuals who access the emails and the method of access.

It notes that the procedure was widespread in most pharmacies in Valladolid capital and one municipality.

With their previous responses, the Primary Care Managements of Valladolid Este and Oeste sent to this AEPD 173 emails exchanged between the investigated pharmacy and the health centers, during the period 05/10/2023 and 18/03/2024. In the emails, "****EMAIL.1" appears as the sender or contact email, and data is indicated in the sections "Prescribing doctor" and "CIP/CIPA of the patient"; as a detected incident, it is indicated "Dispensing window closed" and in the section "Affected medications" it indicates "renew" followed by the word "medication" (in 54 emails) or the name of medications or health products (in 111 emails).

4. On 29/10/2024, a new request for information was made to the Ministry of Health of Castilla y León. In response to this request for information, a report was received prepared by the Pharmaceutical Information and Provision Service in Primary Care, dated 15/11/2024. Regarding the direct communication procedure via emails and the uses made (the three uses initially foreseen and the renewal of prescriptions to patients), the reporting Service indicates that, following the AEPD's request for information dated 27/02/2024, the Primary Care Managements of Valladolid Este and Oeste reviewed their purpose and motivation, evaluated the available alternatives, and identified the actions subject to modification for compliance with data protection, deciding to terminate the validity of the communication procedure.

This decision was communicated to the Health Management of the Valladolid Areas and the College of Pharmacists of Valladolid on May 21, 2024. Therefore, currently, the communication channel subject to the AEPD's request for information is no longer in effect for any of the uses.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Presidency of the Spanish Agency for Data

Protection is competent to initiate and resolve this procedure.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaeapd.gob.es

9/32

II

Procedure

Furthermore, Article 63.2 of the LOPDGDD states that: “The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures.”

In accordance with Article 64 of the LOPDGDD, and taking into account the characteristics of the alleged infringements committed, a sanctioning procedure is initiated.

The procedure shall have a maximum duration of twelve months from the date of the initiation agreement. Upon the expiration of this period, it shall lapse, and consequently, the proceedings shall be archived, in accordance with the provisions established in Article 64 of the LOPDGDD.

If no allegations are made against this initiation agreement within the stipulated period, it may be considered a proposal for resolution, as established in Article 64.2.f) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP).

III

Preliminary Issues

Article 4.1) of the GDPR defines “personal data” as: “any information relating to an identified or identifiable natural person (‘the data subject’); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or one or more specific elements of the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person.”

Article 4.2) of the GDPR defines “processing” as: “any operation or set of operations which is performed on personal data or on sets of personal data, whether or not by automated means, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment or combination, restriction, erasure or destruction.”

Article 4.7) of the GDPR defines the “data controller” or “controller” as: “the natural or legal person, public authority, agency or other body which, alone or jointly with others, determines the purposes and means of the processing; where the purposes and means of such processing are determined by Union law or the law of the Member States, the controller or the specific criteria for its designation may be provided for by Union law or the law of the Member States.” In turn, Article 4.8) of the GDPR defines the “processor” or “processor” as the natural or legal person, public authority, agency or other body which processes personal data on behalf of the controller.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaeapd.gob.es

10/32

In the present case, in accordance with the provisions of Articles 4.1 and 4.2 of the GDPR, there is evidence of the processing of personal data, given that A.A.A. carries out, among other processes, the collection, recording, storage, consultation, or use of personal data of individuals relating to their name and surname, telephone number, personal identification codes, as well as health data (medical treatments), the name of the medical professional assisting them, and the primary healthcare center to which they belong.

A.A.A. conducts this activity in its capacity as the data controller, as it is the entity that determines the purposes and means of such activity, pursuant to Article 4.7 of the GDPR.

It is necessary to emphasize the special nature of the personal data being processed, as they provide

information about individuals' health. Thus, the GDPR establishes a very broad concept of health data and grants them a specific regime, corresponding to the so-called "special categories of data" regulated in Article 9 of the regulatory text.

Health data, according to Article 4.15 of the GDPR, are defined as "personal data relating to the physical or mental health of a natural person, including the provision of health care services, which reveal information about the person's health status."

Regarding health data, Recital 35 of the GDPR states:

"Health-related personal data should include all data concerning the health status of the data subject that provide information about their past, present, or future physical or mental health. This includes information about the natural person collected in connection with their registration for health care purposes, or in connection with the provision of such care, in accordance with Directive 2011/24/EU of the European Parliament and of the Council; any number, symbol, or data assigned to a natural person that uniquely identifies them for health purposes; information obtained from tests or examinations of a part of the body or a bodily substance, including that derived from genetic data and biological samples, and any information relating, for example, to a disease, a disability, the risk of suffering from diseases, medical history, clinical treatment, or the physiological or biomedical status of the data subject, regardless of its source, for example, a doctor or other health professional, a hospital, a medical device, or an in vitro diagnostic test."

The "special categories of data," considering that due to their particularly sensitive nature they incorporate a greater risk, are subject to a higher standard of protection, establishing in the aforementioned Article 9.1 of the GDPR the principle of prohibition of processing, unless one of the circumstances provided for in its paragraph 2 applies.

Recital 51 provides the following regarding special categories of personal data:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeae@aepp.gob.es

11/32

"Special protection is warranted for personal data that, by their nature, are particularly sensitive in relation to fundamental rights and freedoms, as the context of their processing could entail significant risks to those rights and freedoms. [...] Such personal data should not be processed unless their processing is permitted in specific situations contemplated in this Regulation, taking into account that Member States may establish specific provisions on data protection in order to adapt the application of the rules of this Regulation to comply with a legal obligation or to fulfill a task carried out in the public interest or in the exercise of public powers conferred on the data controller. In addition to the specific requirements for such processing, the general principles and other rules of this Regulation must apply, especially regarding the conditions for the lawfulness of processing. Exceptions to the general prohibition on processing these special categories of personal data must be explicitly established, among other things, when the data subject gives explicit consent or in relation to specific needs, particularly when the processing is carried out within the framework of legitimate activities by certain associations or foundations whose aim is to enable the exercise of fundamental freedoms."

IV

Summary of the Facts

Following a complaint filed against A.A.A. and the initial checks carried out, this AEPD became aware of the collection of customer data to send an email, addressed to the respective health center, with the aim of renewing the prescribed medication without the patient having to visit the center. The Health Department of Castilla y León and the Regional Health Management were consulted in this regard. These entities informed that, after the implementation of the Electronic Prescription system in 2015/2016, some difficulties were identified in patients obtaining medications, prompting the Primary Care Management of Valladolid East and West, in 2017, to implement a procedure that allowed pharmacies to communicate to health center professionals possible incidents associated with the prescription of medications.

This procedure, which was required of pharmacies with the collaboration of the Official College of

Pharmacists of Valladolid, contemplated communication between these pharmacies and health centers via email. The pharmacy was to complete and send a form, always via email directed to a management mailbox provided at each center, so that it could be forwarded to the patient's doctor or nurse depending on the type of incident.

This form was designed to be filled out with the pharmacy's data, name of the health center, prescribing doctor, CIP/CIPA of the patient, type of incident, affected medications, and contact details of the pharmacy (telephone number and email address). The incidents that can be resolved through this channel are described ("Dispensing window closed" - when the patient does not collect...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaepe.gob.es

12/32

the medication-, "Error or doubts regarding dosage", "Active treatment that the patient does not use" and "Others") and it is noted that this procedure is not valid for renewals or for closed treatments. However, although it was initially an unforeseen use, this communication system was also used for the renewal of medications.

The procedure established for the Areas of Valladolid was not abandoned until 21/05/2024, once the information requirements issued by the Inspection Services of this AEPD were known.

The documentation collected by the Inspection Services includes 173 emails sent by A.A.A. to health centers, most of which report the renewal of medication as an incident.

It is also verified that the data used to make those communications to the health centers were collected by A.A.A. in its own personal database, separate from the electronic prescription system of the Castilla y León system, consisting of files in "Excel" format detailed in the preceding paragraph Third. In these "Excel" files, A.A.A. notes and retains the information contained in the forms sent to the health centers (name of the health center, name and surname of the prescribing physician, CIP/CIPA of the patient, type of incident or circumstances noted by the pharmacist regarding the medical treatment, affected medications), to which personal data related to the name and surname of the patient/client were added, as well as a notation about the sending of the email.

For the registration of this data in its files, A.A.A. established an automated procedure that allowed the collection of information by passing the patient's health card through the magnetic reader, manually incorporating the medication and the data of the physician and health center, which appear printed on the health card.

The investigation carried out has confirmed that the personal data registered is used by A.A.A. for other purposes, specifically to register the dispensing of the medication in the electronic prescription module of the Castilla y León health system without the patient being present at the pharmacy office, "in case of error in communication, time exceeded, computer error, etc."

The repeated files are stored on the "desktop" of the computers used in the pharmacy office and those located at the public sales counters, without the person in charge having planned for the creation of backup copies or their storage in another location. A.A.A. and all the employees of the establishment (three people at the time of the inspection) can access them, only with the password that protects the computer, known to all.

Finally, regarding the facts presented, A.A.A. stated to the inspection services of this AEPD that it does not provide its clients with any information regarding data protection concerning the described treatments, adding that the client "has visual access at all times to the computer screen to see what is being done."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaepe.gob.es

13/32

Considering the above, it is deemed that there are indications of a possible violation by A.A.A. of the provisions established in Articles 13, 9, and 32 of the GDPR, to the extent expressed in the Legal

Grounds that follow.

V

Unfulfilled obligation: Violation of Article 13 of the GDPR

Considering the processing of personal data carried out, A.A.A. is obliged to comply with the principle of transparency established in Article 5.1 of the GDPR, according to which personal data shall be “processed lawfully, fairly, and in a transparent manner in relation to the data subject (lawfulness, fairness, and transparency)”; and developed in Chapter III, Section 1 of the same Regulation (Articles 12 and following).

Article 12.1 of the GDPR establishes the obligation of the data controller to take appropriate measures to “provide the data subject with all information referred to in Articles 13 and 14, as well as any communication in accordance with Articles 15 to 22 and 34 relating to the processing, in a concise, transparent, intelligible, and easily accessible form, using clear and plain language, in particular any information addressed to a child.”

When personal data is collected directly from the data subject, the information must be provided at the time of that data collection. Article 13 of the GDPR details that information in the following terms:

“1. When personal data is obtained from a data subject, the data controller shall provide the data subject with all the information indicated below at the time of obtaining the data:

- a) the identity and contact details of the controller and, where applicable, of the controller's representative;
- b) the contact details of the data protection officer, where applicable;
- c) the purposes of the processing for which the personal data are intended and the legal basis for the processing;
- d) when the processing is based on Article 6(1)(f), the legitimate interests pursued by the controller or a third party;
- e) the recipients or categories of recipients of the personal data, where applicable;
- f) where applicable, the intention of the controller to transfer personal data to a third country or international organization and the existence or absence of an adequacy decision by the Commission, or, in the case of transfers referred to in Articles 46 or 47 or Article 49(1), second paragraph, reference to the appropriate or suitable safeguards and the means to obtain a copy of them or the place where they have been made available.

2. In addition to the information mentioned in paragraph 1, the data controller shall provide the data subject, at the time when personal data are obtained, with the following information necessary to ensure fair and transparent data processing:

- a) the period for which the personal data will be stored or, when that is not possible...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaepd.gob.es

14/32

possible, the criteria used to determine this period;

- b) the existence of the right to request from the data controller access to personal data concerning the data subject, and its rectification or deletion, or the limitation of its processing, or to object to the processing, as well as the right to data portability;
- c) when the processing is based on Article 6, paragraph 1, letter a), or Article 9, paragraph 2, letter a), the existence of the right to withdraw consent at any time, without affecting the lawfulness of the processing based on consent before its withdrawal;
- d) the right to lodge a complaint with a supervisory authority;
- e) whether the communication of personal data is a legal or contractual requirement, or a requirement necessary to enter into a contract, and whether the data subject is obliged to provide the personal data and is informed of the possible consequences of not providing such data;
- f) the existence of automated decision-making, including profiling, referred to in Article 22, paragraphs 1 and 4, and, at least in such cases, significant information about the logic involved, as well as the

significance and the expected consequences of such processing for the data subject.

3. When the data controller intends to further process personal data for a purpose other than that for which it was collected, it shall provide the data subject, prior to such further processing, information about that other purpose and any relevant additional information in accordance with paragraph 2.

4. The provisions of paragraphs 1, 2, and 3 shall not apply when and to the extent that the data subject already has the information.”

In accordance with these rules, the obligation to inform lies with the data controller and must be provided in advance (Recital 39 of the GDPR).

In this case, A.A.A. stated to the inspection services that it had not provided information to its clients regarding the data processing subject to these proceedings. Therefore, in accordance with the evidence available at this moment in the initiation of the sanctioning procedure, it is considered that the known facts could constitute an infringement, attributable to A.A.A. for violation of the provisions established in Article 13 of the GDPR.

VI

Classification of the infringement of Article 13 of the GDPR and qualification for the purposes of limitation

There is, therefore, evidence of a possible non-compliance with the provisions of Article 13 of the GDPR, which constitutes the commission of an infringement classified under Article 83.5.b) of the same Regulation, which under the heading “General conditions for the imposition of administrative fines” provides the following:

“Violations of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an undertaking, an amount equivalent to a maximum of 4% of the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

15/32

total annual global turnover of the previous financial year, opting for the highest amount:

a) (...)

b) the rights of the interested parties in accordance with Articles 12 to 22;” (...).’

For its part, the LOPDGDD in its Article 71, Offenses, states that:

“Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute offenses.”

For the sole purposes of the statute of limitations, Article 72.1.h) of the LOPDGDD establishes the following:

“1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following are considered very serious offenses and will prescribe after three years:

h) The omission of the duty to inform the affected party about the processing of their personal data in accordance with the provisions of Articles 13 and 14 of Regulation (EU) 2016/679 and 12 of this Organic Law.”

VII

Proposal for sanction

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

“1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 9, and 6 are, in each individual case, effective, proportionate, and dissuasive.”

“2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure for the measures provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected parties and the level

of damage and harm they have suffered;

b) the intentionality or negligence in the infringement;

c) any measures taken by the data controller or processor to mitigate the damage and harm suffered by the affected parties;

d) the degree of responsibility of the data controller or processor, taking into account the technical or organizational measures they have applied under Articles 25 and 32;

e) any previous infringement committed by the data controller or processor;

f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;

g) the categories of personal data affected by the infringement;

h) the manner in which the supervisory authority became aware of the infringement, in particular whether the data controller or processor notified the infringement and, in that case, to what extent;

i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the data controller or processor in relation to the same matter, compliance with those measures;

j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42, and

k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.”

Within this section, the LOPDGDD provides in its Article 76, titled “Sanctions and corrective measures”:

“1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

a) The continued nature of the infringement.

b) The connection of the infringer's activity with the processing of personal data.

c) The benefits obtained as a result of the commission of the infringement.

d) The possibility that the conduct of the affected party may have induced the commission of the infringement.

e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.

f) The impact on the rights of minors.

g) Having, when not mandatory, a data protection officer.

h) The voluntary submission by the data controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any interested party.

3. It will be possible, additionally or alternatively, to adopt, when appropriate, the remaining corrective measures referred to in Article 83.2 of Regulation (EU) 2016/679.”

In this case, considering the seriousness of the possible infringement, especially regarding the consequences that its commission causes to the affected parties, the imposition of a fine would be appropriate, in addition to the adoption of measures, if applicable.

The fine imposed must be, in each individual case, effective, proportionate, and dissuasive, in accordance with the provisions of Article 83.1 of the GDPR. To ensure these principles, the individual entrepreneur status of A.A.A. is considered as a preliminary condition.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaeapd.gob.es

17/32

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment in the initiation agreement of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered appropriate to grade the sanction to be imposed according to the following circumstances, as contemplated in the

aforementioned provisions.

Prior to this, it is deemed that the following circumstances are present:

1. Article 83.2.a) of the GDPR: “a) the nature, severity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected data subjects and the level of damage and harm they have suffered.”
 2. The nature of the infringement: the facts revealed affect a basic principle related to the processing of personal data, such as transparency, which the regulation penalizes with the utmost severity, as it involves processing data of A.A.A. clients without having been adequately informed about such processing.
 3. Severity of the infringement, taking into account the number of records in the files created by A.A.A., as well as the number of data subjects whose personal data are recorded in those files, according to the details outlined in the background of this act.
 4. Duration of the infringement: it is recorded in the proceedings that personal data processing was carried out during the period from 2018 to 2024, according to the details outlined in the background of this act.
 5. Article 83.2.g) of the GDPR: “The categories of personal data affected by the infringement”: the infringement is evident regarding personal data related to the health of the data subjects.
- The balance of the circumstances contemplated in Article 83.2 of the GDPR, concerning the alleged infringement for violation of the provisions of Article 13 of the GDPR, allows for an initial administrative fine of 3,000.00 euros to be set.

VIII

Obligation breached: infringement of Article 9 “Processing of special categories of personal data”

As stated, in the present case we are faced with the processing of personal data related to health, included in the special categories of personal data regulated in Article 9.1 of the GDPR, to which the principle of prohibition of processing applies, unless one of the circumstances provided for in paragraph 2 of that article is present.

This Article 9 of the GDPR, which regulates the processing of special categories of personal data, establishes the following:

“1. The processing of personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, and the processing of genetic data, biometric data aimed at identifying a natural person, is prohibited.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

18/32

unambiguously to an individual, data related to health or data related to the sexual life or sexual orientation of an individual.

2. Paragraph 1 shall not apply when one of the following circumstances occurs:

- a) the data subject has given explicit consent for the processing of such personal data for one or more of the specified purposes, except where Union or Member State law provides that the prohibition mentioned in paragraph 1 cannot be lifted by the data subject;
- b) the processing is necessary for compliance with obligations and the exercise of specific rights of the data controller or the data subject in the field of employment law and social security and protection, to the extent that such processing is authorized by Union or Member State law or a collective agreement under Member State law that establishes adequate safeguards for the respect of fundamental rights and the interests of the data subject;
- c) the processing is necessary to protect vital interests of the data subject or another individual, in the event that the data subject is not physically or legally capable of giving consent;
- d) the processing is carried out, within the scope of its legitimate activities and with appropriate safeguards, by a foundation, association, or any other non-profit body whose purpose is political, philosophical, religious, or trade union-related, provided that the processing relates exclusively to current or former members of such bodies or to persons who have regular contact with them in relation

to their purposes and provided that the personal data are not disclosed outside of them without the consent of the data subjects;

e) the processing concerns personal data that the data subject has made manifestly public;

f) the processing is necessary for the establishment, exercise, or defense of legal claims or when courts are acting in their judicial capacity;

g) the processing is necessary for reasons of substantial public interest, based on Union or Member State law, which must be proportionate to the objective pursued, respect the essence of the right to data protection, and establish appropriate and specific measures to protect the interests and fundamental rights of the data subject;

h) the processing is necessary for purposes of preventive or occupational medicine, the assessment of the worker's capacity to work, medical diagnosis, the provision of health or social care or treatment, or the management of health and social care systems and services, based on Union or Member State law or under a contract with a health professional and without prejudice to the conditions and safeguards provided for in paragraph 3;

i) the processing is necessary for reasons of public interest in the area of public health, such as the protection against serious cross-border threats to health, or

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

19/32

to ensure high levels of quality and safety in healthcare and in medicines or medical products, based on Union Law or the laws of the Member States that establish adequate and specific measures to protect the rights and freedoms of the data subject, in particular professional secrecy;

j) the processing is necessary for archiving purposes in the public interest, for scientific or historical research purposes, or for statistical purposes, in accordance with Article 89, paragraph 1, based on Union Law or the laws of the Member States, which must be proportional to the objective pursued, respect the right to data protection in essence, and establish adequate and specific measures to protect the interests and fundamental rights of the data subject.

3. The personal data referred to in paragraph 1 may be processed for the purposes mentioned in paragraph 2, letter h), when such processing is carried out by a professional subject to the obligation of professional secrecy, or under their responsibility, in accordance with Union Law or the laws of the Member States or with the standards established by the competent national authorities, or by any other person also subject to the obligation of secrecy in accordance with Union Law or the laws of the Member States or the standards established by the competent national authorities.

4. Member States may maintain or introduce additional conditions, including limitations, regarding the processing of genetic data, biometric data, or health-related data."

In the present case, A.A.A. carries out processing of personal data of its clients that includes identification codes assigned by public health systems, medical treatments, or incidents related to such treatments, among others, such as the identity of the doctor and health center providing primary healthcare to the data subject; without the data controller having demonstrated the concurrence of any of the circumstances that allow for lifting the prohibition on processing this special category of personal data established in paragraph 1 of Article 9 of the aforementioned GDPR.

Therefore, in accordance with the evidence available at this moment in the initiation of sanctioning procedure, it is considered that the known facts could constitute an infringement attributable to A.A.A., for violation of the previously transcribed article.

IX

Classification of the infringement of Article 9 of the GDPR and qualification for the purposes of limitation

Article 83.5 of the GDPR classifies as an administrative infringement the violation of the following article, which will be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of a company, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

"a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9;"

For its part, the LOPDGDD in its Article 71, Infringements, states that:

"Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the sole purpose of the limitation period, Article 72.1 of the LOPDGDD establishes the following:

"Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and will prescribe after three years, which involve a substantial violation of the articles mentioned therein and, in particular, the following:

e) The processing of personal data of the categories referred to in Article 9 of Regulation (EU) 2016/679, without any of the circumstances provided for in that provision and in Article 9 of this organic law being present."

X

Proposal for sanction

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR, already transcribed in the Legal Basis VII, must be observed.

In this case, considering the seriousness of the possible infringement, the imposition of a fine would correspond, in addition to the adoption of measures, if appropriate.

The fine imposed must be, in each individual case, effective, proportionate, and dissuasive, in accordance with the provisions of Article 83.1 of the GDPR. As indicated previously, the condition of individual entrepreneur of A.A.A. is considered in advance.

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment in the initiation of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered appropriate to graduate the sanction to be imposed according to the following circumstances, contemplated in the aforementioned provisions.

In advance, it is estimated that the following circumstances are present:

. Article 83.2.a) of the GDPR: "a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of data subjects affected and the level of damage and harm they have suffered."

. The nature of the infringement: the facts revealed are related to one of the basic prohibitions regulated in the GDPR, which the regulation sanctions with the greatest severity.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeae@aepd.gob.es

21/32

. Severity of the infringement, taking into account the number of records that exist in the files created by A.A.A., as well as the number of interested parties whose personal data is recorded in those files, according to the details outlined in the background of this act.

. Duration of the infringement: it is noted in the proceedings that personal data processing was carried out during the period from 2018 to 2024, according to the details outlined in the background of this act.

. Article 76.2.b) of the LOPDGDD: "The link of the infringer's activity with the processing of personal data":

The party being claimed against provides pharmaceutical services, which means that in the course of its usual activities, it regularly needs to process personal data related to health, which impacts the diligence required for compliance with the principles governing the processing of personal data.

The balance of the circumstances considered in Article 83.2 of the GDPR, regarding the alleged infringement for violation of what is established in Article 9 of the GDPR, initially allows for the imposition of an administrative fine in the amount of 10,000.00 euros.

XI

Obligation breached. Security of processing

Article 32 of the GDPR stipulates the following:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context,

and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

2. When assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sede@aepd.gob.es

22/32

4. The data controller and the data processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data in accordance with the instructions of the controller, unless required to do so by Union or Member State law."

Article 32 does not establish static security measures; it is up to controllers and processors to determine the security measures necessary to ensure the confidentiality, integrity, and availability of personal data. Therefore, the same data processing may involve different security measures depending on the specific circumstances in which that data processing takes place.

In line with these provisions, Recital 75 of the GDPR states:

"(75) The risks to the rights and freedoms of natural persons, of varying severity and probability, may arise from the processing of data that could cause physical, material, or immaterial harm, particularly in cases where the processing could lead to issues of discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social harm; in cases where data subjects are deprived of their rights and freedoms or prevented from exercising control over their personal data; in cases where the personal data processed reveal ethnic or racial origin, political opinions, religion or philosophical beliefs, trade union membership, and the processing of genetic data, health data, or data concerning sexual life, or criminal convictions and related security measures; in cases where personal aspects are evaluated, in particular the analysis or prediction of aspects related to work performance, economic situation, health, personal preferences or interests, reliability or behavior, situation or movements, in order to create or use personal profiles; in cases where personal data of vulnerable individuals, particularly children, are processed; or in cases where the processing involves a large amount of personal data and affects a large number of data subjects."

Furthermore, Recital 83 of the GDPR states:

"(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or processor must assess the inherent risks of the processing and apply measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation in relation to the risks and the nature of the personal data to be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data

must be considered, such as the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, which may in particular cause physical, material, or immaterial harm.”

Ultimately, the first step in determining security measures will be the risk assessment. Once assessed, it will be necessary to determine the security measures aimed at reducing or eliminating risks to data processing.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeapd.gob.es
23/32

The security of data requires the application of appropriate technical or organizational measures to the processing of personal data to protect such data against access, use, modification, dissemination, loss, destruction, or accidental, unauthorized, or unlawful damage. In this sense, security measures are key to guaranteeing the fundamental right to data protection. The existence of the fundamental right to the protection of personal data is not possible if the confidentiality, integrity, and availability of such data cannot be guaranteed.

It should not be forgotten that, in accordance with Article 32.1 of the cited GDPR, the technical and organizational measures to be applied to ensure an adequate level of security in relation to the risk must take into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, as well as the variable probability and severity risks to the rights and freedoms of natural persons.

Derived from the activity to which A.A.A. is dedicated, it is obliged to carry out a highly specialized risk analysis and implement appropriate technical and organizational measures to ensure an adequate level of security in relation to the risk of its activity for the rights and freedoms of individuals.

Therefore, when assessing the risks and determining the appropriate technical and organizational measures to ensure an adequate level of security in relation to the risks to the rights and freedoms of natural persons from the data processing it carries out, it is obliged to take into account the specific activity that constitutes its business, which involves the continuous processing of personal data related to health. Thus, the risks arising from its activity must be addressed in a specialized manner.

In the present case, regarding the files that constitute the object of these proceedings, there are indications that lead to the consideration that A.A.A. does not have the appropriate security measures to ensure an adequate level of security in relation to the risk of its personal data processing, with the consequent lack of diligence, as the responsible party, in preventing unauthorized access by third parties.

Evidence that the information systems of the defendant do not have adequate measures, not even the basic ones, to guarantee the confidentiality, integrity, and availability of personal data, are the very statements made by A.A.A. to the Inspection Services of this AEPD when it acknowledges that the repeated files are hosted on the "desktop" of the computers used in the pharmacy office and these located at the public sales counters, allowing customers "visual access at all times to the computer screen"; that it has planned to create backup copies, or that access occurs only with the password that protects the computer, which is unique and known by all the people working in the pharmacy office. Therefore, in accordance with the evidence available at this moment in the initiation of sanctioning procedure agreement, and without prejudice to what results from the instruction, it is considered that the known facts could constitute an infringement, attributable to A.A.A., for violation of Article 32 of the GDPR.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeapd.gob.es
24/32

XII

Typification of the infringement of Article 32 of the GDPR and qualification for the purposes of

prescription

Article 83.4 of the GDPR classifies as an administrative infringement the violation of the following article, which will be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of a company, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

"a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43;"

For its part, the LOPDGDD in its Article 71, Infringements, states that:

"Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the sole purposes of the prescription period, Article 73 of the LOPDGDD establishes the following:

"Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the infringements that constitute a substantial violation of the articles mentioned therein are considered serious and will prescribe after two years, particularly the following:

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security appropriate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679."

XIII

Proposal for sanction

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which are reproduced in Legal Basis VII.

In this case, considering the severity of the possible infringement, the imposition of a fine would be appropriate, in addition to the adoption of measures, if applicable.

The fine imposed must be, in each individual case, effective, proportionate, and dissuasive, in accordance with the provisions of Article 83.1 of the GDPR. To ensure these principles, the individual entrepreneur status of A.A.A. is considered in advance.

For the purposes of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of the initiation of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered appropriate to graduate the sanction to be imposed according to the following circumstances, contemplated in the aforementioned provisions. In advance, the following circumstances are deemed to exist:

. Article 83.2.a) of the GDPR: "a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of affected data subjects and the level of damage and harm they have suffered."

. Severity of the infringement, taking into account the number of records in the files created by A.A.A., as well as the number of data subjects whose personal data is recorded in those files, according to the details noted in the background of this act.

. Duration of the infringement: it is noted in the proceedings that personal data processing was carried out during the period from 2018 to 2024, according to the details noted in the background of this act.

. Article 83.2.b) of the GDPR: "The intentionality or negligence in the infringement."

Considering the risks to privacy involved in the processing of personal data related to health and given that the controller is the owner of a pharmacy, in this case, we are dealing with a serious negligent action.

In this regard, the SAN of October 17, 2007 (rec. 63/2006) is very illustrative, which indicates that "...the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted on rigor and exquisite care to comply with the legal provisions in this regard."

. Article 83.2.g) of the GDPR: "The categories of personal data affected by the infringement": the infringement is evident regarding personal data related to the health of the data subjects.

. Article 76.2.b) of the LOPDGDD: "The link between the infringer's activity and the processing of

personal data”:

The requested party provides pharmaceutical services, so in the development of its own activity, it regularly needs to process personal data related to health.

The balance of the circumstances contemplated in Article 83.2 of the GDPR, regarding the alleged infringement for violation of what is established in Article 13 of the GDPR, allows for an initial administrative fine of 3,000.00 euros to be set.

XIV

Corrective measures

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaepe.gob.es

26/32

If the violations are confirmed, the resolution issued may establish the corrective measures that the infringing entity must adopt to put an end to the non-compliance with personal data protection legislation, in this case, Articles 13, 9, and 32 of the GDPR, in accordance with the provisions of the aforementioned Article 58.2.d) of the GDPR, which states that each supervisory authority may “order the controller or processor to ensure that the processing operations are compliant with the provisions of this Regulation, where appropriate, in a specified manner and within a specified time frame.”

Thus, the responsible entity may be required to align its actions with personal data protection regulations, to the extent expressed in the previous Legal Grounds.

In this act, the presumed infringement committed and the facts that could lead to this possible violation of data protection regulations are established, from which it is clearly inferred what measures are to be adopted, without prejudice to the fact that the type of procedures, mechanisms, or specific instruments for implementing them corresponds to the sanctioned party, as it is the data controller who fully understands its organization and must decide, based on proactive responsibility and a risk-based approach, how to comply with the GDPR and the LOPDGDD.

However, in this case, regardless of the above, in accordance with the evidence available at this moment in the initiation agreement of the sanctioning procedure, the resolution adopted may require A.A.A. to adopt the following measures within two months from the date of enforcement of the resolution concluding this procedure:

1. Eliminate the “Excel” files subject to these proceedings. If this is not possible because it could affect the assistance to the patient and holder of the personal data recorded in those files or any other circumstance that justifies their conservation, it must adopt the necessary measures to ensure the information, preventing it from being accessed improperly by third parties or unauthorized personnel. If processing continues, A.A.A. must adjust its actions to the provisions of Articles 13, 9, and 32 of the GDPR, to the extent expressed in this act.

The imposition of these measures is compatible with the sanction consisting of an administrative fine, as provided for in Article 83.2 of the GDPR.

It is warned that failure to comply with the possible order to adopt measures imposed by this agency in the resolution of the present sanctioning procedure may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in Articles 83.5 and 83.6, and such conduct may lead to the initiation of a further administrative sanctioning procedure.

Furthermore, it is reminded that neither the acknowledgment of the infringement committed nor, where applicable, the voluntary payment of the proposed amounts, exempts the obligation to adopt the necessary measures to cease the conduct or to correct the effects of the infringement committed and to prove compliance with this AEPD.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaepe.gob.es

27/32

obligation.

Therefore, in light of the above, by the Presidency of the Spanish Agency for Data Protection,
IT IS AGREED:

FIRST: TO INITIATE SANCTIONING PROCEDURE against A.A.A., with NIF ***NIF.1,

- for the alleged infringement of Article 13 of the GDPR, classified under Article 83.5.b) of the GDPR, deemed very serious for the purposes of prescription, in Article 72.1.h) of the LOPDGDD.

- for the alleged infringement of Article 9 of the GDPR, classified under Article 83.5.a) of the GDPR, deemed very serious for the purposes of prescription, in Article 72.1.e) of the LOPDGDD.

- for the alleged infringement of Article 32 of the GDPR, classified under Article 83.4 of the GDPR, deemed serious for the purposes of prescription, in Article 73 f) of the LOPDGDD.

SECOND: TO APPOINT B.B.B. as the instructor and C.C.C. as the secretary, indicating that they may be recused, if applicable, in accordance with the provisions of Articles 23 and 24 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (LRJSP).

THIRD: TO INCORPORATE into the file, for evidentiary purposes, as well as the documents obtained and generated by the General Sub-Directorate of Data Inspection in the proceedings prior to the initiation of this sanctioning procedure.

FOURTH: THAT for the purposes provided in Article 64.2 b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the sanction that may correspond would be an administrative fine of 16,000 euros (sixteen thousand euros), without prejudice to what results from the instruction.

- For the alleged infringement of Article 13 of the GDPR, classified under Article 83.5 of that regulation, administrative fine amounting to: 3,000.00 euros.

- For the alleged infringement of Article 9 of the GDPR, classified under Article 83.5 of that regulation, administrative fine amounting to: 10,000.00 euros.

- For the alleged infringement of Article 32 of the GDPR, classified under Article 83.4 of that regulation, administrative fine amounting to: 3,000.00 euros.

Furthermore, the alleged infringement, if confirmed, may entail the imposition of measures, in accordance with the provisions of the aforementioned Article 64.3 of the LOPDGDD.

FIFTH: TO NOTIFY this agreement to A.A.A., with NIF ***NIF.1, granting a hearing period of ten working days for them to submit allegations and present any evidence they deem appropriate. In their written allegations, they must provide their NIF and the procedure number that appears in the heading of this document.

In accordance with the provisions of Article 85 of the LPACAP, they may acknowledge their responsibility within the period granted for the submission of allegations to this initiation agreement; this will entail a 20% reduction of the sanction that may be imposed in this procedure. With the application of this reduction, the sanction would be set at 12,800 euros (twelve thousand eight hundred euros), resolving the procedure with the imposition of this sanction. Similarly, they may, at any time prior to the resolution of this procedure, voluntarily pay the proposed sanction, which will imply a 20% reduction of its amount. With the application of this reduction, the sanction would be set at 12,800 euros (twelve thousand eight hundred euros) and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

The reduction for the voluntary payment of the sanction is cumulative to the one corresponding to the acknowledgment of responsibility, provided that this acknowledgment of responsibility is made within the period granted for submitting allegations to the opening of the procedure. The voluntary payment of the amount referred to in the previous paragraph may be made at any time prior to the resolution. In this case, if both reductions were to apply, the amount of the sanction would be set at 9,600 euros (nine thousand six hundred euros).

In any case, the effectiveness of either of the two mentioned reductions will be conditioned upon the withdrawal or renunciation of any action or administrative appeal against the sanction.

In the event that they choose to proceed with the voluntary payment of any of the amounts indicated above (12,800 or 9,600 euros), they must make the payment by depositing it into account No. IBAN: ES00-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX) opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A., indicating in the concept the reference number of the procedure that appears in the heading of this document and the reason for

the reduction of the amount to which they are adhering.

They must also send the proof of payment to the General Sub-Directorate of Inspection along with the express communication of the withdrawal or renunciation of any action or administrative appeal against the sanction to continue with the procedure in accordance with the amount deposited.

Finally, it is noted that in accordance with the provisions of Article 112.1 of the LPACAP, there is no administrative appeal against this act.

1479-200325

Lorenzo Cotino Hueso

President of the Spanish Agency for Data Protection

>>

SECOND: On April 10, 2025, A.A.A. proceeded to pay the sanction in the amount of 9,600.00 euros, making use of the two reductions provided for in the previously transcribed initiation agreement, which implies the acknowledgment of the

29/32

responsibility in relation to the facts referred to in the initiation agreement and its legal qualification.

THIRD: The previously transcribed initiation agreement indicated that, if the infringement were confirmed, it could be agreed to impose on the responsible party the adoption of appropriate measures to adjust their actions to the regulations mentioned in this act, in accordance with the provisions of the aforementioned article 58.2 d) of the GDPR, according to which each supervisory authority may "order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified period...".

Having recognized the responsibility for the infringement, the imposition of the measures included in the initiation agreement is appropriate.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the guarantee of digital rights (hereinafter, LOPDGDD), the Presidency of the Spanish Agency for Data Protection is competent to resolve this procedure.

Furthermore, article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Termination of the procedure

Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), under the heading "Termination in sanctioning procedures" provides as follows:

"1. Once a sanctioning procedure has been initiated, if the infringer acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.

2. When the sanction is solely of a pecuniary nature or when it is possible to impose a pecuniary sanction and another of a non-pecuniary nature but the impropriety of the latter has been justified, voluntary payment by the alleged responsible party, at any time prior to the resolution, will imply the termination of the procedure, except regarding the restoration of the altered situation or the determination of compensation for the damages caused by the commission of the infringement.

3. In both cases, when the sanction is solely of a pecuniary nature, the competent body to resolve the procedure shall apply reductions of at least 20% on the amount of the proposed sanction, which shall be cumulative. The aforementioned reductions must be specified in the notification of initiation of the procedure, and their effectiveness will be conditioned on the withdrawal or renunciation of any action or administrative appeal against the sanction. The percentage of reduction provided in this section may be increased by regulation."

III

Voluntary payment and acknowledgment of responsibility

In accordance with the provisions of the aforementioned article 85 of the LPACAP, the notified initiation agreement informed about the possibility of acknowledging responsibility and making the voluntary payment of the proposed sanction, which would imply two cumulative reductions of 20% each. With the application of these two reductions, the sanction would be set at 9,600.00 euros, and its payment would imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

Following the notification of the aforementioned initiation agreement, A.A.A. has proceeded to acknowledge responsibility and make the voluntary payment of the sanction, availing themselves of the two reductions provided. In accordance with section 3 of article 85 LPACAP, the effectiveness of the aforementioned reductions will be conditioned on the withdrawal or renunciation of any action or administrative appeal against the sanction.

It should be noted that, according to the provisions of the LPACAP, as well as the jurisprudence of the Supreme Court in this matter, the exercise of voluntary payment by the alleged responsible party does not exempt the administration from the obligation to resolve and notify all procedures, regardless of their form of initiation. Likewise, article 88 of the aforementioned regulation establishes that the resolution that concludes the procedure will decide all issues raised by the interested parties and any others arising from it.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of sanctions, the Presidency of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE the commission of the infringements and TO CONFIRM the sanctions determined in the dispositive part of the initiation agreement transcribed in this resolution.

The sum of the aforementioned amounts results in a total amount of 16,000.00 euros.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

31/32

After A.A.A. has proceeded with the prompt payment and acknowledgment of responsibility, it is hereby resolved, pursuant to Article 85 of the LPACAP, to reduce the total amount mentioned by 40%, which results in a final amount of 9,600.00 euros.

The effectiveness of the aforementioned reductions is, in any case, conditioned upon the withdrawal or renunciation of any action or appeal in the administrative pathway.

SECOND: DECLARE the termination of procedure EXP202313747, in accordance with the provisions of Article 85 of the LPACAP.

THIRD: ORDER A.A.A. to notify the Agency of the adoption of the measures described in the legal grounds of the initiation agreement transcribed in this resolution, within a period of 2 months from the date this resolution becomes firm and enforceable.

FOURTH: NOTIFY this resolution to A.A.A.

FIFTH: In accordance with the provisions of Article 85 of the LPACAP, which conditions the reduction for voluntary payment and acknowledgment of responsibility upon the withdrawal or renunciation of any action or appeal in the administrative pathway, this resolution shall be firm in the administrative pathway and fully enforceable from the date of its notification.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative pathway as prescribed by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the interested parties may file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating Contentious-Administrative

Jurisdiction, within a period of two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

However, in accordance with the provisions of Article 90.3.a) of the LPACAP, the firm resolution in the administrative pathway may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeaepd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency does not become aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

1259-260325

Lorenzo Cotino Hueso

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaepd.gob.es

32/32

President of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaepd.gob.es